



University of Piraeus
School of Information and Communication Technologies
Department of Digital Systems

Level: Master's Programme of Studies

Wireless and Mobile Network Security

Case 7

Supervising Professors: Christos Xenakis and Georgios Efthymoglou

Ioannis Kalaitzidis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

Abstract

Implementation of the EAP-PEAP authentication method within the IEEE 802.1X framework, through the creation of a controlled Rogue Access Point using hostapd-wpe on Kali Linux. Practical capture of NTLMv2 credential hashes from a simulated enterprise client.

Abstract

Implementation of an EAP-PEAP authentication method within the IEEE 802.1X standard, through the creation of a controlled Rogue Access Point using the hostapd-wpe software. Due to hardware limitations of the wireless adapter during the transition to Master mode, the advanced technique of virtual interfaces (mac80211_hwsim) was utilized for the successful execution of the experiment. Recording of the results for the successful interception of credentials (MSCHAPv2 hashes) and practical demonstration of the inherent vulnerabilities that arise in wireless networks when the client does not strictly verify the server's digital certificate.

Contents

Introduction.....	
-------------------	--

Practical part of the assignment.....	
Bibliography.....	12

Introduction

The IEEE 802.1X standard constitutes the basic framework for Port-Based Network Access Control (PNAC). In enterprise wireless networks (WPA2/WPA3-Enterprise), it replaces the simple Pre-Shared Key with a RADIUS authentication server.

In modern enterprise networks (WPA2/WPA3-Enterprise), the use of the EAP-PEAP (Protected EAP) method has become standard. EAP-PEAP establishes an encrypted TLS tunnel that protects the transmission of the client's credentials.

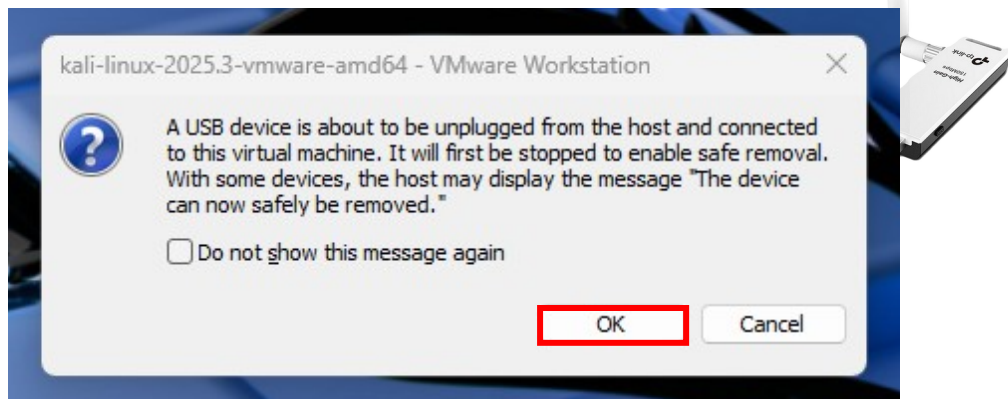
To highlight precisely these risks, this exercise focuses on creating a controlled Rogue Access Point that mimics a legitimate enterprise network, with the goal of intercepting the NTLMv2 hash of a simulated client's credentials.

Practical part of the assignment

The TP-Link TL-WN722N adapter was connected to VMware and assigned exclusively to Kali Linux.

VMware confirmed the standard connection message.

The



iwconfig command verified successful interface recognition.

Kali Linux recognised the adapter as wlan0. The hostapd-wpe tool was selected for the simultaneous implementation of the Authenticator and Authentication Server.

```
(kali@kali)-[~]
$ sudo airmon-ng check kill
[sudo] password for kali:
Killing these processes:

    PID Name
    2347 wpa_supplicant

(kali@kali)-[~]
$
```

For the simultaneous implementation of the Authenticator and Authentication Server, the hostapd-wpe tool was selected.

After confirming the tool's installation, the next step involved the parametrisation of the central configuration file.

```
Session Actions Edit View Help
GNU nano 8.6 /etc/hostapd-wpe
# Configuration file for hostapd-wpe
# Interface - Probably wlan0 for 802.11, eth0 for wired
interface=wlan0

# May have to change these depending on build location
eap_user_file=/etc/hostapd-wpe/hostapd-wpe.eap_user
ca_cert=/etc/hostapd-wpe/certs/ca.pem
server_cert=/etc/hostapd-wpe/certs/server.pem
private_key=/etc/hostapd-wpe/certs/server.key
private_key_passwd=whatever
dh_file=/etc/hostapd-wpe/certs/dh

# 802.11 Options
ssid=JK_Enterprise
channel=1

# WPE Options - Dont need to change these to make it all work
#
# wpe_logfile=somefile # (Default: ./hostapd-wpe.log)
# wpe_hb_send_before_handshake=0 # Heartbleed True/False (Default: 1)
# wpe_hb_send_before_apdata=0 # Heartbleed True/False (Default: 0)
# wpe_hb_send_after_apdata=0 # Heartbleed True/False (Default: 0)
# wpe_hb_payload_size=0 # Heartbleed 0-65535 (Default: 50000)
# wpe_hb_num_repeats=0 # Heartbleed 0-65535 (Default: 1)
# wpe_hb_num_tries=0 # Heartbleed 0-65535 (Default: 1)
```

After saving the parameters, an attempt was made to start the Rogue Access Point service.

This specific error is a known hardware limitation. Although the TP-Link card (with Ralink chipset) supports Monitor Mode and packet injection, it does not support the creation of virtual AP interfaces (AP mode) via hostapd.

To overcome this technical obstacle and allow uninterrupted analysis of the 802.1X protocol, a virtual network adapter (wlan2) was created using iw.

Next, the server's configuration file (/etc/hostapd-wpe/hostapd-wpe.conf) was modified using nano to point to the virtual wlan2 interface.

Since the network now exists exclusively in the virtual space of the operating system kernel, the wpa_supplicant service was used to simulate a client device attempting to connect.

To implement the test, a new configuration file for the client (/etc/wpa_supplicant_test.conf) was created.

After completing the parametrisation, the connection command was executed in a new terminal window (sudo wpa_supplicant -i wlan2 -c /etc/wpa_supplicant_test.conf).

The execution of the above command triggered the start of the communication. The virtual client (wlan2) connected to the virtual Rogue AP, initiating the EAP-PEAP authentication dialogue.

As observed in the server recording (hostapd-wpe), the Rogue Access Point detected the connection attempt and successfully captured the NTLMv2 hash of the client's credentials.

Conclusion

In conclusion, this assignment successfully implemented the development of an EAP authentication method (specifically EAP-PEAP), which constitutes the cornerstone of modern enterprise wireless network security.

During the practical application, physical limitations arose at the hardware level (hardware/driver limitations) from the TP-Link adapter. These were methodologically overcome through the use of virtual interfaces.

Finally, the successful simulation of a controlled Rogue Access Point via the specialised hostapd-wpe tool demonstrated the feasibility of the attack: an attacker who creates a fake enterprise network and induces clients to connect can capture NTLMv2 hashes and attempt offline cracking via hashcat.

Bibliography

- 802.1X-2020 - IEEE Standard for Local and Metropolitan Area Networks--Port-Based Network Access Control. (n.d.). Retrieved from <https://ieeexplore.ieee.org/document/9018454>
- RFC 3748: Extensible Authentication Protocol (EAP). (n.d.). Retrieved from <https://datatracker.ietf.org/doc/html/rfc3748>
- RFC 2759: Microsoft PPP CHAP Extensions, Version 2. (n.d.). Retrieved from <https://datatracker.ietf.org/doc/html/rfc2759>
- OpenSecurityResearch. (n.d.). GitHub - OpenSecurityResearch/hostapd-wpe: Modified hostapd to facilitate AP impersonation attacks. Retrieved from <https://github.com/OpenSecurityResearch/hostapd-wpe>
- TLS-based EAP types and TLS 1.3. (n.d.). Retrieved from <https://datatracker.ietf.org/doc/html/draft-ietf-emu-tls-eap-types-02>
- Linux WPA Supplicant (IEEE 802.1X, WPA, WPA2, WPA3, RSN, IEEE 802.11I). (n.d.). Retrieved from https://w1.fi/wpa_supplicant/